S.G.R.S.I

Sistema de Gestión de Recursos y Soporte de Informática

CiberSeguridad

EnterpriceDeKlan

Rol	Apellido	Nombre	documento identidad	email
Coordinador	Gonzaléz	Julian	5.742892-8	julian.gonzalez.arrascaeta@gmail.com
Sub-Coordinador	Cuello	Santiago	5731237-3	augustocrafter22@gmail.com
Integrante 1	Forcelledo	Ezequiel	5724706-7	ezequielforcelledo9@gmail.com
Integrante 2	Venis	Federico	6486057-3	fede.venis@gmail.com

Docente: Nibia Venturino

Tercera ENTREGA

Fecha de entrega:

23 oct 2026

CETP

1. PRINCIPALES POSIBLES ATAQUES SOBRE EL SISTEMA 3
1.1 MÉTODOS DE PROTECCIÓN 3
1.1.1 Inyecciones SQL 3
1.1.2 Ataques al login a fuerza bruta 4
1.1.3 CSRF 4
1.1.4 XSS 4
1.1.5 Exposición de datos sensibles 4
1.2 MÉTODOS DE DETECCIÓN 5
1.2.1 Detección inyecciones SQL 5
1.2.2 Detección Ataques al login a fuerza bruta 5
1.2.3 Detección de CSRF 5
1.2.4 Detección de XSS (Cross Site Scripting) 5
1.2.5 Detección de exposición de datos sensibles 6
2. MAPA CONCEPTUAL 6
3. POLÍTICAS DE SEGURIDAD Y MARCO NORMATIVO 7
3.1 Políticas de seguridad de la empresa 7
3.1.1 Política de autenticación y contraseñas 7
3.1.2 Política de tratamiento de datos 7
3.1.3 Política de validación de formularios 7
3.1.4 Política de gestión de credenciales 7
3.1.5 Política de registro y monitoreo 8
3.2 Marco normativo 8
3.2.1 Ley 18.331 8
3.2.2 Ley 19.670 8
3.2.3 Unidad Reguladora y de Control de Datos Personales (URCDP) 8

1. PRINCIPALES POSIBLES ATAQUES SOBRE EL SISTEMA

1. Inyecciones SQL
2. Ataques al Login
3. CSRF
4. XSS (Cross Site Scripting)
5. Exposición de datos sensibles

Estos son los problemas que nuestra empresa detectó como posibles vulnerabilidades al sistema debido a la estructura que presenta la aplicación. Estos posibles ataques son tomados en cuenta y se presentan medidas para contrarrestar la falencia del programa.

1.1 MÉTODOS DE PROTECCIÓN

1.1.1 Inyecciones SQL

Las inyecciones SQL son cuando se pasan formularios con implementación de extras a la consulta realizada a la base de datos, nosotros para solventar ese problema de posibles inyecciones SQL desarrollamos el uso de consultas parametrizadas o estructuradas y evitando concatenar las variables de la consulta.

1.1.2 Ataques al login a fuerza bruta

Los ataques de fuerza bruta es cuando se intenta pasar la contraseña probando varias veces hasta que se da con la correcta. La solución encontrada fue almacenar las contraseñas en variables cifradas y limitar la cantidad de intentos por sesión, así evitando intentos ilimitados en una sesión que supondría un riesgo.

1.1.3 CSRF

La falsificación de solicitudes entre sitios se da cuando un usuario entra a otra página luego de haber iniciado sesión en el sistema, dicha página roba los datos guardados en la sesión y vulnera con dichos datos robados. Este problema fue neutralizado haciendo uso de un token aleatorio llamado CSRF token, que se genera de forma aleatoria y se valida con cada formulario que modifica datos. Es decir, verifica la identidad de la sesión antes de hacer cualquier acción sensible.

1.1.4 XSS

Cross site scripting se refiere a la vulnerabilidad que tienen las páginas web con inserción de código que se puede instalar o alojar de diferentes maneras. La forma de evitar este problema es usando una función de PHP que vuelve a los caracteres especiales (<, >, ”, ‘) en caracteres inofensivos.

1.1.5 Exposición de datos sensibles

Ciertos datos, como las credenciales de la base de datos se encuentran dentro de la carpeta raíz de la app, pero son un dato sensible que de ser filtrado supone una amenaza. Nuestra solución fue descargar una extensión llamada dotenv para guardar las credenciales en un archivo seguro. Además también centramos la actividad del usuario en una rama que no supone la carpeta raíz de la app.

1.2 MÉTODOS DE DETECCIÓN

1.2.1 Detección inyecciones SQL

Para detectar esta vulnerabilidad hay que revisar los registros de errores de PHP y de Apache, porque cuando alguien mete comillas o código SQL sospechoso en un formulario normalmente se generan errores o consultas que no corresponden. También se deben hacer algunas pruebas manuales escribiendo cosas como (OR 1=1) en el login y en los buscadores, para comprobar que el sistema no responde como si fuera una

consulta válida. Si en los registros aparecen muchos errores de consulta seguidos, quiere decir que alguien está probando.

1.2.2 Detección Ataques al login a fuerza bruta

La detección de los ataques al login se realizan llevando la cuenta de los intentos fallidos de inicio de sesión. Si un mismo usuario o una misma dirección IP falla muchas veces en poco tiempo, se considera sospechoso. Esos intentos se pueden guardar en la base de datos o en un archivo de registro con la fecha y la hora, para que después el administrador pueda revisarlos.

1.2.3 Detección de CSRF

Se detecta cuando llega un formulario donde el token CSRF no existe o no coincide con el que está guardado en la sesión. Cada vez que pasa eso, el sistema rechaza la acción y queda anotada en el registro porque un formulario no sospechoso siempre otorga el token correcto. Si aparecen muchos tokens inválidos, quiere decir que se están enviando solicitudes desde otro lugar.

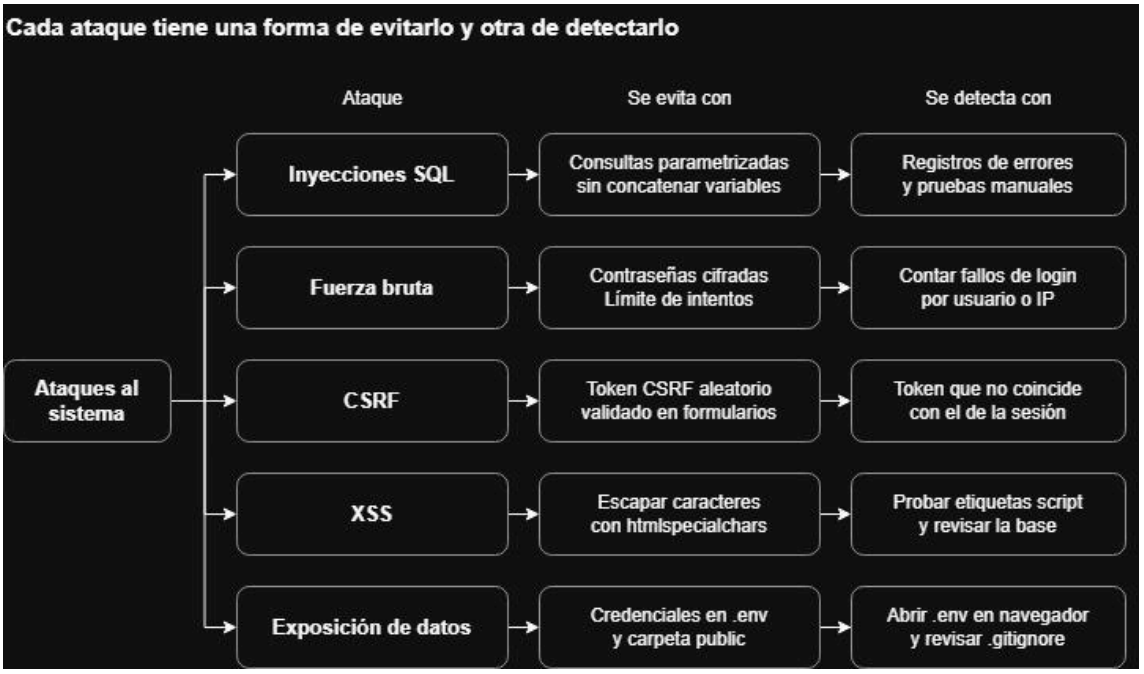
1.2.4 Detección de XSS (Cross Site Scripting)

Su detección se realiza probando escribir etiquetas como (<script>alert('prueba')</script>) en los campos de texto, por ejemplo en el título o la descripción de un ticket, y después se revisa que al mostrarse en pantalla aparezca como texto y no se ejecute. También se pueden revisar los datos guardados en la base buscando si hay etiquetas (<script>) donde no deberían estar, porque eso indica que alguien intentó inyectar código.

1.2.5 Detección de exposición de datos sensibles

Se comprueba intentando abrir el archivo “.env” escribiendo su dirección en el navegador. Si el servidor lo muestra, hay un problema de configuración y si da error de acceso o no lo encuentra, está bien protegido. Además se tiene que comprobar que el archivo esté dentro del “.gitignore” para que no se suba al repositorio de GitHub por error, y que los errores de PHP no muestren rutas ni datos de la conexión a la base de datos.

2. MAPA CONCEPTUAL



3. POLÍTICAS DE SEGURIDAD Y MARCO NORMATIVO

3.1 Políticas de seguridad de la empresa

Las políticas de seguridad de DeKlan Enterprice son las reglas que seguimos al desarrollar y mantener el sistema. Salen directamente de los ataques que identificamos en el punto 1, y su objetivo es proteger la información de los usuarios y que el sistema funcione de forma confiable.

3.1.1 Política de autenticación y contraseñas

Las contraseñas se almacenan cifradas mediante una función de hash y nunca en texto plano, de modo que, ante una filtración de la base de datos, no queden expuestas. Además, se limita la cantidad de intentos de inicio de sesión por sesión, para mitigar los ataques de fuerza bruta.

3.1.2 Política de tratamiento de datos

Toda consulta a la base de datos se ejecuta mediante sentencias preparadas, sin concatenar variables en el código SQL, lo que previene las inyecciones SQL. Asimismo, los datos ingresados por el usuario se sanitizan antes de mostrarse en pantalla, convirtiendo los caracteres especiales en entidades HTML, lo que evita la ejecución de scripts (XSS).

3.1.3 Política de validación de formularios

Todo formulario que modifique datos incluye un token CSRF, generado de forma aleatoria y asociado a la sesión del usuario. El servidor valida el token antes de procesar la solicitud y la rechaza si este no existe o no coincide.

3.1.4 Política de gestión de credenciales

Las credenciales de conexión a la base de datos se almacenan como variables de entorno en un archivo .env, que se excluye del repositorio mediante .gitignore. Además, el servidor web expone únicamente la carpeta pública de la aplicación, por lo que el resto de los archivos no es accesible desde el navegador.

3.1.5 Política de registro y monitoreo

Los errores del sistema y los intentos fallidos de autenticación se registran con fecha y hora. El administrador revisa estos registros periódicamente para identificar patrones sospechosos y actuar a tiempo.

3.2 Marco normativo

El sistema almacena y procesa datos personales de sus usuarios, por lo cual las políticas anteriores se respaldan en la normativa uruguaya sobre protección de datos personales.

3.2.1 Ley 18.331

La Ley 18.331 de Protección de Datos Personales es la norma principal en la materia. Su artículo 10 establece el principio de seguridad de los datos, que obliga al responsable de la base de datos a adoptar las medidas necesarias para garantizar la seguridad y la confidencialidad de los datos personales, evitando su adulteración, pérdida, consulta o tratamiento no autorizado.

3.2.2 Ley 19.670

La Ley 19.670 complementa el principio de seguridad de los datos, reforzando la obligación de implementar medidas de seguridad y de responder por su cumplimiento.

3.2.3 Unidad Reguladora y de Control de Datos Personales (URCDP)

La URCDP es el encargado de supervisar el cumplimiento de la ley y según la Ley 18.331, puede aplicar sanciones ante su incumplimiento. Por este motivo, resulta necesario mantener las medidas de protección y el registro de actividad definidos en las políticas.